

# Web 應用程式報告

這份報告包含關於 Web 應用程式的重要安全資訊。

## 安全報告

這份報告是由 HCL AppScan Standard 所建立 10.11.1  
掃描開始時間：2026/6/4 下午2:50:12

# 目錄

## 簡介

- 一般資訊
- 登入設定值

## 摘要

- 問題類型
- 有漏洞的 URL
- 修正建議
- 安全風險
- 原因
- WASC 威脅分類

## 依問題類型分組的問題

- 未強制加密 <sup>1</sup>
- 檢查是否有 SRI (子資源完整性) 支援 <sup>1</sup>
- 缺少或不安全的 Cross-Origin-Embedder-Policy (COEP) 標頭 <sup>1</sup>
- 缺少或不安全的 Cross-Origin-Opener-Policy (COOP) 標頭 <sup>1</sup>
- 缺少或不安全的跨來源資源政策 (CORS) 標頭 <sup>1</sup>
- 所顯示的 Spring Boot Actuator 端點 <sup>1</sup>
- 找到可快取的 SSL 頁面 <sup>1</sup>
- 遺漏「Content-Security-Policy」標頭 <sup>1</sup>
- 遺漏或不安全的 "X-Content-Type-Options" 標頭 <sup>1</sup>
- 遺漏或不安全的 HTTP Strict-Transport-Security 標頭 <sup>1</sup>
- 遺漏「查閱者原則」安全標頭 <sup>1</sup>

## 如何修正

- 未強制加密
- 檢查是否有 SRI (子資源完整性) 支援
- 缺少或不安全的 Cross-Origin-Embedder-Policy (COEP) 標頭
- 缺少或不安全的 Cross-Origin-Opener-Policy (COOP) 標頭
- 缺少或不安全的跨來源資源政策 (CORS) 標頭
- 所顯示的 Spring Boot Actuator 端點
- 找到可快取的 SSL 頁面
- 遺漏「Content-Security-Policy」標頭

- 遺漏或不安全的 "X-Content-Type-Options" 標頭
- 遺漏或不安全的 HTTP Strict-Transport-Security 標頭
- 遺漏「查閱者原則」安全標頭

## 應用程式資料

- Cookie
- JavaScript
- 參數
- 註解
- 造訪的 URL
- 失敗要求
- 已過濾的 URL
- 元件

# 簡介

這份報告包含由 HCL AppScan Standard 執行 Web 應用程式安全掃描的結果。

|                |    |
|----------------|----|
| 中嚴重性問題：        | 5  |
| 低嚴重性問題：        | 5  |
| 參考資訊嚴重性問題：     | 1  |
| 報告中併入的安全問題總計：  | 11 |
| 掃描中探索到的安全問題總計： | 11 |

## 一般資訊

|          |                    |
|----------|--------------------|
| 掃描檔名：    | 未命名                |
| 掃描開始時間：  | 2026/6/4 下午2:50:12 |
| 測試原則：    | Default            |
| CVSS 版本： | 3.1                |
| 測試最佳化等級： | 快速                 |

|          |                 |
|----------|-----------------|
| 主機       | meqa.ncu.edu.tw |
| 埠        | 443             |
| 作業系統：    | Win32           |
| Web 伺服器： | IIS             |
| 應用程式伺服器： | 任何              |

## 登入設定值

|                      |        |
|----------------------|--------|
| 登入方法：                | 已記錄的登入 |
| 並行登入：                | 已啟用    |
| 階段作業內偵測：             | 已啟用    |
| 階段作業內型樣：             |        |
| 已追蹤或階段作業 ID Cookies： |        |
| 已追蹤或階段作業 ID 參數：      |        |
| 登入序列：                |        |

# 摘要

## 問題類型 11

目錄

| 問題類型 |                                                  | 問題數目 |             |
|------|--------------------------------------------------|------|-------------|
| 中    | 未強制加密                                            | 1    | <div></div> |
| 中    | 檢查是否有 SRI ( 子資源完整性 ) 支援                          | 1    | <div></div> |
| 中    | 缺少或不安全的 Cross-Origin-Embedder-Policy ( COEP ) 標頭 | 1    | <div></div> |
| 中    | 缺少或不安全的 Cross-Origin-Opener-Policy (COOP) 標頭     | 1    | <div></div> |
| 中    | 缺少或不安全的跨來源資源政策 ( CORP ) 標頭                       | 1    | <div></div> |
| 低    | 所顯示的 Spring Boot Actuator 端點                     | 1    | <div></div> |
| 低    | 找到可快取的 SSL 頁面                                    | 1    | <div></div> |
| 低    | 遺漏「Content-Security-Policy」標頭                    | 1    | <div></div> |
| 低    | 遺漏或不安全的 "X-Content-Type-Options" 標頭              | 1    | <div></div> |
| 低    | 遺漏或不安全的 HTTP Strict-Transport-Security 標頭        | 1    | <div></div> |
| 參    | 遺漏「查閱者原則」安全標頭                                    | 1    | <div></div> |

## 有漏洞的 URL 4

目錄

| URL |                                               | 問題數目 |             |
|-----|-----------------------------------------------|------|-------------|
| 中   | https://meqa.ncu.edu.tw/                      | 8    | <div></div> |
| 中   | https://meqa.ncu.edu.tw/nurvo/                | 1    | <div></div> |
| 低   | https://meqa.ncu.edu.tw/nurvo/api/            | 1    | <div></div> |
| 低   | https://meqa.ncu.edu.tw/nurvo/api/auth/google | 1    | <div></div> |

## 修正建議 11

目錄

| 補救作業 |                                                                                | 問題數目 |             |
|------|--------------------------------------------------------------------------------|------|-------------|
| 中    | 將「Cross-Origin-Embedder-Policy」( COEP ) 標頭新增或修改為「require-corp」                 | 1    | <div></div> |
| 中    | 將每一個第三方 Script/鏈結元素支援新增至 SRI ( 子資源完整性 ) 。                                      | 1    | <div></div> |
| 中    | 添加或修改「Cross-Origin-Opener-Policy」( COOP ) 標頭為「same-origin」                     | 1    | <div></div> |
| 中    | 添加或修改「Cross-Origin-Resource-Policy」( CORP ) 標頭為「same-origin」或「same-site」       | 1    | <div></div> |
| 中    | 當傳送機密性資訊時，強制使用 HTTPS                                                           | 1    | <div></div> |
| 低    | 使用長式 "max-age" 實作 HTTP Strict-Transport-Security 原則                            | 1    | <div></div> |
| 低    | 在 SSL 頁面的回應中新增 "Cache-Control: no-store" 和 "Pragma: no-cache" 標頭，以防止快取 SSL 頁面。 | 1    | <div></div> |
| 低    | 配置 Spring Server Endpoints 僅允許存取已鑑別的使用者                                        | 1    | <div></div> |
| 低    | 配置伺服器利用 "nosniff" 值使用 "X-Content-Type-Options" 標頭                              | 1    | <div></div> |
| 低    | 配置伺服器利用安全原則使用 "Content-Security-Policy" 標頭                                     | 1    | <div></div> |
| 低    | 配置您的伺服器，以搭配安全原則使用「查閱者原則」標頭                                                     | 1    | <div></div> |

安全風險 4

目錄

| 風險 |                                                   | 問題數目 |
|----|---------------------------------------------------|------|
| 中  | 有可能竊取以未加密方式傳送的機密資料，如：信用卡號碼、社會保險號碼等等               | 1    |
| 中  | 假設第三方伺服器已受損，網站的內容/行為會變更                           | 1    |
| 中  | 有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置   | 9    |
| 低  | 有可能說服無經驗而易受騙的使用者提供機密性資訊，如：使用者名稱、密碼、信用卡號碼、社會保險號碼等等 | 4    |

原因 5

目錄

| 原因 |                                 | 問題數目 |
|----|---------------------------------|------|
| 中  | 機密性輸入欄位（如：使用者名稱、密碼和信用卡號碼）傳遞時未加密 | 1    |
| 中  | 不支援 SRI (子資源完整性)                | 1    |
| 中  | 不安全的 Web 應用程式設計或配置              | 7    |
| 低  | 使用不安全的方式配置 Web 伺服器或應用程式伺服器      | 1    |
| 低  | 瀏覽器可能已快取機密性資訊                   | 1    |

WASC 威脅分類 2

目錄

| 威脅 |        | 問題數目 |
|----|--------|------|
| 中  | 資訊洩漏   | 10   |
| 中  | 併入遠端檔案 | 1    |

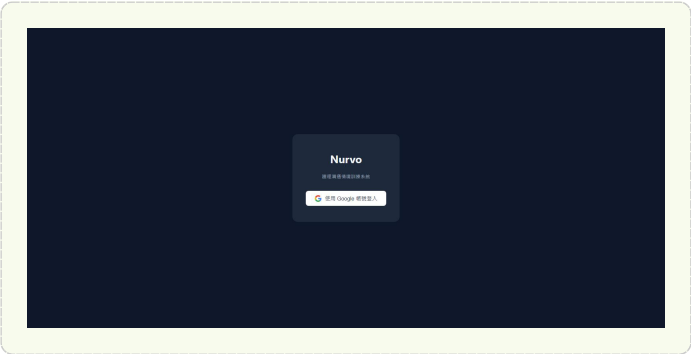
# 依問題類型分組的問題

| 未強制加密        |                                                            |
|--------------|------------------------------------------------------------|
| 嚴重性：         | 中                                                          |
| 狀態：          | 待解決                                                        |
| CVSS 3.1 向量： | AV:A/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N                        |
| CVSS 3.1 評分： | 5.4                                                        |
| CVSS 4.0 向量： | AV:A/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N/E:X |
| CVSS 4.0 評分： | 5.3                                                        |
| URL：         | https://meqa.ncu.edu.tw/                                   |
| 實體：          | meqa.ncu.edu.tw (Page)                                     |
| 風險：          | 有可能竊取以未加密方式傳送的機密資料，如：信用卡號碼、社會保險號碼等等                        |
| 原因：          | 機密性輸入欄位（如：使用者名稱、密碼和信用卡號碼）傳遞時未加密                            |
| 修正：          | 當傳送機密性資訊時，強制使用 HTTPS                                       |

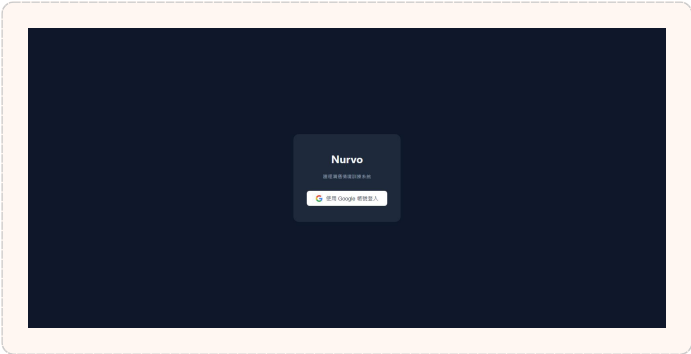
差異：架構 操作來源：https 到：http  
埠 操作來源：443 到：80  
標頭 Host 操作來源：meqa.ncu.edu.tw 到：meqa.ncu.edu.tw:80

推論：測試回應與原始回應非常類似。這表示已順利使用 HTTP（而非 HTTPS）存取資源。

原始回應



測試回應



|                         |                                                           |
|-------------------------|-----------------------------------------------------------|
| 檢查是否有 SRI ( 子資源完整性 ) 支援 |                                                           |
| 嚴重性：                    | 中                                                         |
| 狀態：                     | 待解決                                                       |
| CVSS 3.1 向量：            | AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N                       |
| CVSS 3.1 評分：            | 5.3                                                       |
| CVSS 4.0 向量：            | AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N/EX |
| CVSS 4.0 評分：            | 6.9                                                       |
| URL：                    | https://meqa.ncu.edu.tw/nurvo/                            |
| 實體：                     | (Page)                                                    |
| 風險：                     | 假設第三方伺服器已受損，網站的內容/行為會變更                                   |
| 原因：                     | 不支援 SRI ( 子資源完整性 )                                        |
| 修正：                     | 將每一個第三方 Script/鏈結元素支援新增至 SRI ( 子資源完整性 )。                  |

差異：

推論： 第三方連結/腳本沒有完整性屬性，使瀏覽器無法確認它們是否未被破壞。

原始測試回應：

```
...

<!DOCTYPE html>
<html lang="zh-TW">
  <head>
    <meta charset="UTF-8">
    <link rel="icon" href="/nurvo/favicon.ico">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <link rel="preconnect" href="https://fonts.googleapis.com">
    <link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
    <link href="https://fonts.googleapis.com/css2?family=Inter:wght@400;500;600;700;800&display=swap"
rel="stylesheet">
    <title>Nurvo</title>
    <script type="module" crossorigin src="/nurvo/assets/index-BtQqzhMN.js"></script>
    <link rel="stylesheet" crossorigin href="/nurvo/assets/index-CFQXcnSs.css">
  </head>
  <body>
    <div id="app"></div>
  </body>
</html>

...
```

中

缺少或不安全的 Cross-Origin-Embedder-Policy ( COEP ) 標頭 1

目錄



## 缺少或不安全的 Cross-Origin-Embedder-Policy ( COEP ) 標頭

|              |                                                                 |
|--------------|-----------------------------------------------------------------|
| 嚴重性：         | 中                                                               |
| 狀態：          | 待解決                                                             |
| CVSS 3.1 向量： | AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N                             |
| CVSS 3.1 評分： | 4.2                                                             |
| CVSS 4.0 向量： | AV:N/AC:H/AT:N/PR:N/UI:P/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N/E:X      |
| CVSS 4.0 評分： | 2.3                                                             |
| URL：         | <a href="https://meqa.ncu.edu.tw/">https://meqa.ncu.edu.tw/</a> |
| 實體：          | meqa.ncu.edu.tw (Page)                                          |
| 風險：          | 有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置                 |
| 原因：          | 不安全的 Web 應用程式設計或配置                                              |
| 修正：          | 將「Cross-Origin-Embedder-Policy」( COEP ) 標頭新增或修改為「require-corp」  |

差異：

推論：AppScan 檢測到「Cross-Origin-Embedder-Policy」( COEP ) 標頭要麼缺失，要麼設置為不安全的值。

原始測試回應：

```
HTTP/1.1 200 OK
Content-Type: text/html
Last-Modified: Wed, 27 May 2026 13:47:18 GMT
Accept-Ranges: bytes
ETag: "6a82dc55dfeddc1:0"
Server: Microsoft-IIS/10.0
Date: Thu, 04 Jun 2026 06:50:21 GMT
Content-Length: 705

<!DOCTYPE html>
<html lang="zh-TW">
  <head>
    <meta charset="UTF-8">
    <link rel="icon" href="/nurvo/favicon.ico">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <link rel="preconnect" href="https://fonts.googleapis.com">
    <link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
    <link href="https://fonts.googleapis.com/css2?family=Inter:wght@400;500;600;700;800&display=swap"
rel="stylesheet">
    <title>Nurvo</title>
    <script type="module" crossorigin src="/nurvo/assets/index-BtQqzhMN.js"></script>
    ...
```

## 中 缺少或不安全的 Cross-Origin-Opener-Policy (COOP) 標頭 1

目錄

問題 1 / 1

目錄

## 缺少或不安全的 Cross-Origin-Opener-Policy (COOP) 標頭

|              |                                                                 |
|--------------|-----------------------------------------------------------------|
| 嚴重性：         | 中                                                               |
| 狀態：          | 待解決                                                             |
| CVSS 3.1 向量： | AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N                             |
| CVSS 3.1 評分： | 4.8                                                             |
| CVSS 4.0 向量： | AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N/E:X      |
| CVSS 4.0 評分： | 6.3                                                             |
| URL：         | <a href="https://meqa.ncu.edu.tw/">https://meqa.ncu.edu.tw/</a> |
| 實體：          | meqa.ncu.edu.tw (Page)                                          |
| 風險：          | 有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置                 |
| 原因：          | 不安全的 Web 應用程式設計或配置                                              |
| 修正：          | 添加或修改「Cross-Origin-Opener-Policy」(COOP) 標頭為「same-origin」        |

差異：

推論：AppScan 檢測到「Cross-Origin-Opener-Policy」(COOP) 標頭要麼缺失，要麼設置為不安全的值。

原始測試回應：

```
HTTP/1.1 200 OK
Content-Type: text/html
Last-Modified: Wed, 27 May 2026 13:47:18 GMT
Accept-Ranges: bytes
ETag: "6a82dc55dfeddc1:0"
Server: Microsoft-IIS/10.0
Date: Thu, 04 Jun 2026 06:50:21 GMT
Content-Length: 705

<!DOCTYPE html>
<html lang="zh-TW">
  <head>
    <meta charset="UTF-8">
    <link rel="icon" href="/nurvo/favicon.ico">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <link rel="preconnect" href="https://fonts.googleapis.com">
    <link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
    <link href="https://fonts.googleapis.com/css2?family=Inter:wght@400;500;600;700;800&display=swap"
rel="stylesheet">
    <title>Nurvo</title>
    <script type="module" crossorigin src="/nurvo/assets/index-BtQqzhMN.js"></script>
    ...
```

## 中 缺少或不安全的跨來源資源政策 (CORS) 標頭 1

目錄

問題 1 / 1

目錄

## 缺少或不安全的跨來源資源政策 ( CORP ) 標頭

|              |                                                                          |
|--------------|--------------------------------------------------------------------------|
| 嚴重性：         | 中                                                                        |
| 狀態：          | 待解決                                                                      |
| CVSS 3.1 向量： | AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N                                      |
| CVSS 3.1 評分： | 4.8                                                                      |
| CVSS 4.0 向量： | AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N/E:X               |
| CVSS 4.0 評分： | 6.3                                                                      |
| URL：         | <a href="https://meqa.ncu.edu.tw/">https://meqa.ncu.edu.tw/</a>          |
| 實體：          | meqa.ncu.edu.tw (Page)                                                   |
| 風險：          | 有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置                          |
| 原因：          | 不安全的 Web 應用程式設計或配置                                                       |
| 修正：          | 添加或修改「Cross-Origin-Resource-Policy」( CORP ) 標頭為「same-origin」或「same-site」 |

差異：

推論：AppScan 檢測到 "Cross-Origin-Resource-Policy" (CORP) 標頭要麼缺失，要麼設置為不安全的值。

原始測試回應：

```
HTTP/1.1 200 OK
Content-Type: text/html
Last-Modified: Wed, 27 May 2026 13:47:18 GMT
Accept-Ranges: bytes
ETag: "6a82dc55dfeddc1:0"
Server: Microsoft-IIS/10.0
Date: Thu, 04 Jun 2026 06:50:21 GMT
Content-Length: 705

<!DOCTYPE html>
<html lang="zh-TW">
  <head>
    <meta charset="UTF-8">
    <link rel="icon" href="/nurvo/favicon.ico">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <link rel="preconnect" href="https://fonts.googleapis.com">
    <link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
    <link href="https://fonts.googleapis.com/css2?family=Inter:wght@400;500;600;700;800&display=swap"
rel="stylesheet">
    <title>Nurvo</title>
    <script type="module" crossorigin src="/nurvo/assets/index-BtQqzhMN.js"></script>
    ...
```

問題 1 / 1

目錄

## 所顯示的 Spring Boot Actuator 端點

|              |                                                                                     |
|--------------|-------------------------------------------------------------------------------------|
| 嚴重性：         | 低                                                                                   |
| 狀態：          | 待解決                                                                                 |
| CVSS 3.1 向量： | AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N                                                 |
| CVSS 3.1 評分： | 3.7                                                                                 |
| CVSS 4.0 向量： | AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N/E:X                          |
| CVSS 4.0 評分： | 6.3                                                                                 |
| URL：         | <a href="https://mega.ncu.edu.tw/nurvo/api/">https://mega.ncu.edu.tw/nurvo/api/</a> |
| 實體：          | health (Page)                                                                       |
| 風險：          | 有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置                                     |
| 原因：          | 使用不安全的方式配置 Web 伺服器或應用程式伺服器                                                          |
| 修正：          | 配置 Spring Server Endpoints 僅允許存取已鑑別的使用者                                             |

差異：路徑 操作來源：</nurvo/api/auth/google> 到：</nurvo/api/health>

推論：測試回應包含所要求 Spring Endpoint 的內容，表示會向非授權的使用者暴露。

問題 1 / 1

目錄

## 找到可快取的 SSL 頁面

|              |                                                                                                           |
|--------------|-----------------------------------------------------------------------------------------------------------|
| 嚴重性：         | 低                                                                                                         |
| 狀態：          | 待解決                                                                                                       |
| CVSS 3.1 向量： | AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N                                                                       |
| CVSS 3.1 評分： | 3.7                                                                                                       |
| CVSS 4.0 向量： | AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N/EX                                                 |
| CVSS 4.0 評分： | 6.3                                                                                                       |
| URL：         | <a href="https://meqa.ncu.edu.tw/nurvo/api/auth/google">https://meqa.ncu.edu.tw/nurvo/api/auth/google</a> |
| 實體：          | google (Page)                                                                                             |
| 風險：          | 有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置                                                           |
| 原因：          | 瀏覽器可能已快取機密性資訊                                                                                             |
| 修正：          | 在 SSL 頁面的回應中新增 "Cache-Control: no-store" 和 "Pragma: no-cache" 標頭，以防止快取 SSL 頁面。                            |

差異：

推論：應用程式的回應指出系統應對頁面進行快取，但是您未設定快取控制項（您可以設定「Cache-Control: no-store」或「Cache-Control: no-cache」或「Pragma: no-cache」來阻止系統快取）。

原始測試回應：

```
HTTP/1.1 200 OK
Content-Type: application/json
Server: Microsoft-IIS/10.0
X-Powered-By: ARR/3.0
Date: Thu, 04 Jun 2026 06:53:16 GMT
Content-Length: 309

{
  "url": "https://accounts.google.com/o/oauth2/v2/auth?client_id=779063245534-d2bj5jr7ut6i6e3q1vkha9lhq2l36ft5.apps.googleusercontent.com&redirect_uri=https%3A%2F%2Fmeqa.ncu.edu.tw%2Fnurvo%2Fapi%2Fauth%2Fgoogle%2Fcallback&response_type=code&scope=openid+email+profile&access_type=offline&prompt=select_account"
}...
```

低 遺漏「Content-Security-Policy」標頭 1

目錄

問題 1 / 1

目錄

## 遺漏「Content-Security-Policy」標頭

|              |                                                                                                      |
|--------------|------------------------------------------------------------------------------------------------------|
| 嚴重性：         | 低                                                                                                    |
| 狀態：          | 待解決                                                                                                  |
| CVSS 3.1 向量： | AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N                                                                  |
| CVSS 3.1 評分： | 3.7                                                                                                  |
| CVSS 4.0 向量： | AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N/EX                                            |
| CVSS 4.0 評分： | 6.3                                                                                                  |
| URL：         | <a href="https://meqa.ncu.edu.tw/">https://meqa.ncu.edu.tw/</a>                                      |
| 實體：          | meqa.ncu.edu.tw (Page)                                                                               |
| 風險：          | 有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置<br>有可能說服無經驗而易受騙的使用者提供機密性資訊，如：使用者名稱、密碼、信用卡號碼、社會保險號碼等等 |
| 原因：          | 不安全的 Web 應用程式設計或配置                                                                                   |
| 修正：          | 配置伺服器利用安全原則使用 "Content-Security-Policy" 標頭                                                           |

差異：

推論：AppScan 偵測到遺漏 Content-Security-Policy 回應標頭或包含不安全的原則，這會增加各種跨網站注入攻擊的暴露風險

原始測試回應：

```
...

Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://meqa.ncu.edu.tw/nurvo/login
Accept-Encoding: gzip
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Content-Type: application/json
Server: Microsoft-IIS/10.0
X-Powered-By: ARR/3.0
Date: Thu, 04 Jun 2026 06:53:16 GMT
Content-Length: 309

{
  "url": "https://accounts.google.com/o/oauth2/v2/auth?client_id=779063245534-d2bj5jr7ut6i6e3qlvkha9lhq2l36ft5.apps.googleusercontent.com&redirect_uri=https%3A%2F%2Fmeqa.ncu.edu.tw%2Fnurvo%2Fapi%2Fauth%2Fgoogle%2Fcallback&response_type=code&scope=openid+email+profile&access_type=offline&prompt=select_account"
}

...
```

低 遺漏或不安全的 "X-Content-Type-Options" 標頭 1

目錄

問題 1 / 1

目錄

## 遺漏或不安全的 "X-Content-Type-Options" 標頭

|              |                                                                                                      |
|--------------|------------------------------------------------------------------------------------------------------|
| 嚴重性：         | 低                                                                                                    |
| 狀態：          | 待解決                                                                                                  |
| CVSS 3.1 向量： | AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N                                                                  |
| CVSS 3.1 評分： | 3.7                                                                                                  |
| CVSS 4.0 向量： | AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N/EX                                            |
| CVSS 4.0 評分： | 6.3                                                                                                  |
| URL：         | <a href="https://meqa.ncu.edu.tw/">https://meqa.ncu.edu.tw/</a>                                      |
| 實體：          | meqa.ncu.edu.tw (Page)                                                                               |
| 風險：          | 有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置<br>有可能說服無經驗而易受騙的使用者提供機密性資訊，如：使用者名稱、密碼、信用卡號碼、社會保險號碼等等 |
| 原因：          | 不安全的 Web 應用程式設計或配置                                                                                   |
| 修正：          | 配置伺服器利用 "nosniff" 值使用 "X-Content-Type-Options" 標頭                                                    |

差異：

推論：AppScan 偵測到遺漏 X-Content-Type-Options 回應標頭或具有不安全的值，這會增加路過式下載攻擊的暴露風險

原始測試回應：

```
...

Sec-Fetch-Dest: document
sec-ch-ua: "Chromium";v="145", "Not:A-Brand";v="99"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Accept-Encoding: gzip
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Content-Type: text/html
Last-Modified: Wed, 27 May 2026 13:47:18 GMT
Accept-Ranges: bytes
ETag: "6a82dc55dfeddc1:0"
Server: Microsoft-IIS/10.0
Date: Thu, 04 Jun 2026 06:53:18 GMT
Content-Length: 705

<!DOCTYPE html>
...
```

## 低 遺漏或不安全的 HTTP Strict-Transport-Security 標頭 1

目錄

問題 1 / 1

目錄

## 遺漏或不安全的 HTTP Strict-Transport-Security 標頭

|              |                                                                                                      |
|--------------|------------------------------------------------------------------------------------------------------|
| 嚴重性：         | 低                                                                                                    |
| 狀態：          | 待解決                                                                                                  |
| CVSS 3.1 向量： | AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N                                                                  |
| CVSS 3.1 評分： | 3.7                                                                                                  |
| CVSS 4.0 向量： | AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N/EX                                            |
| CVSS 4.0 評分： | 6.3                                                                                                  |
| URL：         | <a href="https://meqa.ncu.edu.tw/">https://meqa.ncu.edu.tw/</a>                                      |
| 實體：          | meqa.ncu.edu.tw (Page)                                                                               |
| 風險：          | 有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置<br>有可能說服無經驗而易受騙的使用者提供機密性資訊，如：使用者名稱、密碼、信用卡號碼、社會保險號碼等等 |
| 原因：          | 不安全的 Web 應用程式設計或配置                                                                                   |
| 修正：          | 使用長式 "max-age" 實作 HTTP Strict-Transport-Security 原則                                                  |

差異：

推論：AppScan 偵測到遺漏 HTTP Strict-Transport-Security 回應標頭或是 "max-age" 不足

原始測試回應：

```
HTTP/1.1 200 OK
Content-Type: text/html
Last-Modified: Wed, 27 May 2026 13:47:18 GMT
Accept-Ranges: bytes
ETag: "6a82dc55dfeddc1:0"
Server: Microsoft-IIS/10.0
Date: Thu, 04 Jun 2026 06:53:20 GMT
Content-Length: 705

<!DOCTYPE html>
<html lang="zh-TW">
  <head>
    <meta charset="UTF-8">
    <link rel="icon" href="/nurvo/favicon.ico">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <link rel="preconnect" href="https://fonts.googleapis.com">
    <link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
    <link href="https://fonts.googleapis.com/css2?family=Inter:wght@400;500;600;700;800&display=swap"
rel="stylesheet">
    <title>Nurvo</title>
    <script type="module" crossorigin src="/nurvo/assets/index-BtQqzhMN.js"></script>
    ...
```



## 問題 1 / 1

目錄

## 遺漏「查閱者原則」安全標頭

|              |                                                                                                      |
|--------------|------------------------------------------------------------------------------------------------------|
| 嚴重性：         | <a href="#">參考資訊</a>                                                                                 |
| 狀態：          | 待解決                                                                                                  |
| CVSS 3.1 向量： | AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N/E:X/RL:O/RC:C                                                    |
| CVSS 3.1 評分： | 0.0                                                                                                  |
| CVSS 4.0 向量： | AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N/E:X                                           |
| CVSS 4.0 評分： | 0                                                                                                    |
| URL：         | <a href="https://meqa.ncu.edu.tw/">https://meqa.ncu.edu.tw/</a>                                      |
| 實體：          | meqa.ncu.edu.tw (Page)                                                                               |
| 風險：          | 有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置<br>有可能說服無經驗而易受騙的使用者提供機密性資訊，如：使用者名稱、密碼、信用卡號碼、社會保險號碼等等 |
| 原因：          | 不安全的 Web 應用程式設計或配置                                                                                   |
| 修正：          | <a href="#">配置您的伺服器</a> ，以搭配安全原則使用「查閱者原則」標頭                                                          |

差異：

推論：AppScan 偵測到查閱者原則回應標頭遺漏或包含不安全的原则，這會增加各種跨網站注入攻擊的暴露風險

原始測試回應：

```
HTTP/1.1 200 OK
Content-Type: application/json
Server: Microsoft-IIS/10.0
X-Powered-By: ARR/3.0
Date: Thu, 04 Jun 2026 06:50:23 GMT
Content-Length: 309

{
  "url": "https://accounts.google.com/o/oauth2/v2/auth?client_id=779063245534-d2bj5jr7ut6i6e3qlvkha9lhq2l36ft5.apps.googleusercontent.com&redirect_uri=https%3A%2F%2Fmeqa.ncu.edu.tw%2Fnurvo%2Fapi%2Fauth%2Fgoogle%2Fcallback&response_type=code&scope=openid+email+profile&access_type=offline&prompt=select_account"
}...
```

# 如何修正

## 未強制加密

目錄

原因：

- 應用程式未使用 TLS/SSL 這類安全通道來交換機密性資訊。
- 具有網路資料流量存取權的攻擊者可以透過連線來竊聽封包。此攻擊在技術上並不難，但確實需要實體存取網路中機密資料所經過的某個部分。

風險：

任何以明碼形式傳送至伺服器的資訊都可能透過網路進行竊取，並在稍後用於身分竊取或使用者模擬。  
可能可以截取到以未加密形式傳送的機密資料，例如 使用者登入資訊（使用者名稱和密碼）、信用卡號碼、社會保險號碼等。  
可能可以執行攔截式 (MitM) 攻擊，讓攻擊者完全控制通訊，包括變更內容、竊取資料，或向伺服器模擬使用者。

修正建議：

一般

您應該一律只透過 TLS/SSL 連線來傳輸所有資料。這包括所有外部通訊，例如瀏覽器、資料庫這類後端連線、第三方 API 及其他服務。  
此外，還有數個隱私規範指出一律會將使用者認證這類機密性資訊以加密形式傳送至網站。  
一律強制使用加密連線（例如 TLS/SSL），而且不容許使用未加密 HTTP 對機密性資訊進行任何存取。  
使用 TLS 1.2 或 TLS 1.3，以及使用高度加密雜湊演算法和密碼組合。

CWE：

311  
319  
200

外部參照：

OWASP - TLS 密碼字串速查表  
OWASP - 傳輸層保護速查表

## 檢查是否有 SRI（子資源完整性）支援

目錄

原因：

子資源完整性不受支援。

風險：

用戶代理並不驗證來自第三方服務的腳本。如果第三方服務被破壞，用戶將無法得到保護。來自其他域的腳本和鏈接標籤不支持完整性檢查。如果托管腳本的服務被破壞，這種漏洞可能會被利用。

不支援SRI的範例腳本元素：

```
<script src="https://example.com/example-framework.js" crossorigin="anonymous"></script>
```

範例劇本元素支持SRI：

```
<script src="https://example.com/example-framework.js" integrity="sha384-Li9vy3DqF8tnTXuiaAJuML3ky+er10rcgNR/VqsVpcw+ThHmYcwiB1pbOxEbzJr7" crossorigin="anonymous"></script>
```

受影響的產品：  
這個問題可能會影響不同類型的產品。

修正建議：

一般

將「子資源完整性」新增至每一個 Script/鏈結（其原始碼不在您網域中）  
W3C 子資源完整性：  
<https://www.w3.org/TR/SRI/>  
SRI雜湊生成器：  
<https://srihash.org>  
不支援SRI的範例腳本元素：  
`<script src="https://example.com/example-framework.js" crossorigin="anonymous"></script>`  
範例劇本元素支援SRI：  
`<script src="https://example.com/example-framework.js" integrity="sha384-oqVuAfXRKap7fdgcCY5uykM6+R9GqQ8K/uxy9rx7HNQlIGYI1kPzQho1wx4JwY8wC" crossorigin="anonymous"></script>`

CWE：  
829  
669  
830  
354  
345

外部參照：  
[FrontPage 伺服器延伸：安全考量說明](#)

## 缺少或不安全的 Cross-Origin-Embedder-Policy ( COEP ) 標頭

[目錄](#)

原因：  
不安全的網頁應用程式編程或配置

風險：  
嵌入跨來源資源（如腳本或圖像）而不設限制，會使您的網站容易受到不受信任的代碼執行和側信道洩漏的攻擊。攻擊者可以包含不使用正確CORS標頭的不透明第三方資源，即使沒有直接的腳本執行，也會創造安全漏洞。這種攻擊向量依賴於靜默地引入繞過驗證的第三方資源。  
如果沒有 COEP，攻擊者可以嵌入不受信任的資源，繞過 CORS 的強制執行，從而導致數據洩漏，並破壞安全 API 所需的跨來源隔離。

受影響的產品：  
此問題可能會影響不同類型的產品。

修正建議：

一般

將標頭 "Cross-Origin-Embedder-Policy: require-corp" 設置為強制僅加載啟用 CORS 或同源的資源。

CWE：  
200

外部參照：  
[OWASP 安全標頭專案 - COEP](#)

## 缺少或不安全的 Cross-Origin-Opener-Policy (COOP) 標頭

[目錄](#)

### 原因：

不安全的網頁應用程式編程或配置

### 風險：

現代瀏覽器允許窗口和標籤頁相互交互，即使它們來自不同的來源。這種行為可能會使您的網站暴露於跨來源側信道攻擊，因為它允許惡意網站與您的網站共享瀏覽上下文。攻擊向量涉及攻擊者在新標籤頁或iframe中打開您的網站，並使用像>window.openner'這樣的共享引用。

在沒有 COOP 的情況下，惡意網站可以在新標籤頁中打開您的頁面，並利用共享的瀏覽上下文進行側信道攻擊，可能洩露跨來源數據，例如會話令牌或敏感內容。

### 受影響的產品：

此問題可能影響不同類型的產品。

### 修正建議：

一般

將標頭設置為 "Cross-Origin-Opener-Policy: same-origin"，以確保您的網站在一個單獨的瀏覽上下文組中運行，將其與其他來源隔離。

### CWE：

200

### 外部參照：

[OWASP 安全標頭專案 - COOP](#)

## 缺少或不安全的跨來源資源政策 ( CORP ) 標頭

[目錄](#)

### 原因：

不安全的網頁應用程式編程或配置

### 風險：

網頁應用程式通常提供靜態資源，例如圖像、腳本或 API，這些資源不應被其他網站嵌入或重用。若沒有保護，惡意網站可能會嵌入您的資源並提取敏感數據，有時甚至會利用計時攻擊或通過瀏覽器行為洩露元數據。這種情況發生在資源未受保護且可跨來源自由訪問時。

沒有 CORP，第三方網站可能會嵌入並濫用您的私人資源，從而導致數據洩漏或在已驗證的會話中進行搭載。

### 受影響的產品：

此問題可能影響不同類型的產品。

### 修正建議：

一般

將資源的「 Cross-Origin-Resource-Policy 」標頭設置為「 same-origin 」或「 same-site 」，以防止第三方未經授權的嵌入或重用。

### CWE：

200

### 外部參照：

[OWASP 安全標頭專案 - CORP](#)

## 所顯示的 Spring Boot Actuator 端點

### 原因：

使用不安全的方式配置 Web 伺服器或應用程式伺服器

### 風險：

有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置

Spring Boot 包含多項功能，可協助監視及管理正式作業中的應用程式。

擧動器端點允許監視應用程式，並與應用程式互動。Spring Boot 包含數個內建的端點，同時也可以新增其他端點。

由於端點可能包含機密性資訊，當您公開端點時，請謹慎考慮。

務必僅向已授權的使用者公開端點，並避免其他使用者存取該端點。

### 受影響的產品：

已啟動端點的 Spring Boot Actuator。

### 修正建議：

#### 一般

1. 僅啟用作業所需的 Spring Server 端點。
2. 僅在必要時向遠端存取公開端點。
3. 將端點限制為僅供授權使用者使用，以保障端點安全（例如僅具有 ENDPOINT\_ADMIN 角色的使用者）。

### CWE：

200

497

### 外部參照：

Spring Boot 擧動器：正式作業就緒功能（端點）

## 找到可快取的 SSL 頁面

### 原因：

瀏覽器可能已快取機密性資訊

### 風險：

有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置

依預設，大部分 Web 瀏覽器都配置成會在使用期間快取使用者的頁面。這表示也會快取 SSL 頁面。不建議讓 Web 瀏覽器儲存任何 SSL 資訊，因為當有弱點存在時，可能會危及這個資訊。

### 受影響的產品：

這個問題可能會影響不同類型的產品。

### 修正建議：

#### 一般

在所有 SSL 頁面及含有機密資料的所有頁面上，停用快取。

這可以透過在您的 SSL 頁面標頭中使用 "Cache-Control: no-store" 及 "Pragma: no-cache" 或 "Cache-Control: no-cache" 回應指引達成。

Cache-Control: private - 這個指引指示 Proxy 頁面含有私密資訊，因此不應藉由共用快取進行快取。不過，它不會指示瀏覽器不要進行頁面快取。

Cache-Control: no-cache - 這個指引也會指示 Proxy 頁面含有私密資訊，因此不能進行快取。它也會指示瀏覽器要向伺服器重新驗證，檢查是否有新的版本。這表示瀏覽器可以儲存敏感性頁面或資訊，在重新驗證時使用。某些瀏覽器不一定會遵循 RFC，因此可能會將 no-cache 視為 no-store。

Cache-Control: no-store - 這是最安全的指引。它指示 Proxy 和瀏覽器不要快取頁面或將頁面儲存在快取資料夾。

Pragma: no-cache - 不支援 Cache-Control 標頭的舊瀏覽器需要這項指引。

## CWE：

525  
524  
668  
200

## 遺漏「Content-Security-Policy」標頭

目錄

### 原因：

不安全的 Web 應用程式設計或配置

### 風險：

有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置

有可能讓無經驗而易受騙的使用者信以為真而提供機密資訊，例如：使用者名稱、密碼、信用卡號碼、社會保險號碼等等

缺少 CSP 或設定不適當的值，可能會導致 Web 應用程式遭受 XSS、點擊劫持等攻擊。

「Content-Security-Policy」標頭的目的是在於修改瀏覽器呈現頁面的方式，進而預防各種跨網站注入攻擊，包括跨網站 跨網站指令碼。請務必設定正確的標頭值，避免網站運作不良。例如，如果將標頭設定為禁止執行行內 JavaScript，網站就不能在頁面中使用行內 JavaScript。

為了抵禦跨網站指令碼、跨框架 Scripting 及點擊劫持，請務必設定以下原則並提供適當的值：

「default-src」和「frame-ancestors」原則兩者，\*或\*「script-src」、「object-src」及「frame-ancestors」原則三者。

對於「default-src」、「script-src」及「object-src」，請避免「\*」、「data:」、「unsafe-inline」或「unsafe-eval」這類不安全的值。

對於「frame-ancestors」，請避免「\*」或「data:」這類不安全的值。

此外，對於「script-src」和「default-src」（「script-src」的後援指引），一般認為「self」是不安全的，應避免使用。

如需詳細資訊，請參考以下鏈結。

請注意，「Content-Security-Policy」包含四個不同的測試。有個一般測試會驗證「Content-Security-Policy」標頭是否正在使用中，其他三個測試會檢查「Frame-Ancestors」、「Object-Src」和「Script-Src」是否正確設定。

### 受影響的產品：

此問題可能會影響不同類型的產品

### 修正建議：

#### 一般

設定您的伺服器以傳送「Content-Security-Policy」標頭。

建議您將 Content-Security-Policy 標頭設定為其指引的安全值，如下所示：

對於「default-src」和「script-src」，安全值包括「none」或 <https://any.example.com>。

對於「frame-ancestors」和「object-src」，預期的安全值包括「self」、「none」或 <https://any.example.com> 等。

「unsafe-inline」和「unsafe-eval」絕不能使用。使用暫時 / 雜湊只能是短期替代方案。

若為 Apache 伺服器，請參閱：

[http://httpd.apache.org/docs/2.2/mod/mod\\_headers.html](http://httpd.apache.org/docs/2.2/mod/mod_headers.html)

若為 IIS 伺服器，請參閱：

<https://technet.microsoft.com/pl-pl/library/cc753133%28v=ws.10%29.aspx>

若為 nginx 伺服器，請參閱：

[http://nginx.org/en/docs/http/nginx\\_headers\\_module.html](http://nginx.org/en/docs/http/nginx_headers_module.html)

## CWE：

1032  
79  
693  
830  
1021

### 外部參照：

幾個安全的標頭清單

「內容安全原則 (Content Security Policy)」的簡介

MDN web docs - Content-Security-Policy

## 遺漏或不安全的 "X-Content-Type-Options" 標頭

### 原因：

不安全的 Web 應用程式設計或配置

### 風險：

有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置  
有可能說服無經驗而易受騙的使用者提供機密性資訊，如：使用者名稱、密碼、信用卡號碼、社會保險號碼等等  
具有 "nosniff" 值的 "X-Content-Type-Options" 標頭可防止 IE 和 Chrome 忽視回應的內容類型。  
此動作可防止使用者的瀏覽器（例如在惡意命名後）執行未受信任的內容（例如使用者上傳的內容）。

### 受影響的產品：

此問題可能會影響不同類型的產品

### 修正建議：

一般

配置您的伺服器，在所有送出的要求上使用值為 "nosniff" 的 "X-Content-Type-Options" 標頭。

若為 Apache 伺服器，請參閱：

[http://httpd.apache.org/docs/2.2/mod/mod\\_headers.html](http://httpd.apache.org/docs/2.2/mod/mod_headers.html)

若為 IIS 伺服器，請參閱：

<https://technet.microsoft.com/pl-pl/library/cc753133%28v=ws.10%29.aspx>

若為 nginx 伺服器，請參閱：

[http://nginx.org/en/docs/http/nginx\\_headers\\_module.html](http://nginx.org/en/docs/http/nginx_headers_module.html)

### CWE：

200

693

### 外部參照：

有用的 HTTP 標頭清單

減少 MIME 類型的安全風險

## 遺漏或不安全的 HTTP Strict-Transport-Security 標頭

### 原因：

不安全的 Web 應用程式設計或配置

### 風險：

有可能收集 Web 應用程式相關的機密性資訊，如：使用者名稱、密碼、機器名稱及/或機密檔案位置  
有可能說服無經驗而易受騙的使用者提供機密性資訊，如：使用者名稱、密碼、信用卡號碼、社會保險號碼等等  
HTTP Strict Transport Security (HSTS) 這個機制可保護安全的 (HTTPS) 網站不被降級到不安全的 HTTP。這個機制可以讓 Web 伺服器指示用戶端（Web 瀏覽器或其他使用者代理程式）在與伺服器互動時使用安全的 HTTPS 連線，並且永不使用不安全的 HTTP 通訊協定。  
請務必將 'max-age' 設為夠高的值，以防止提前切換回不安全的連線。  
HTTP Strict Transport Security 原則是為何伺服器使用名為 "Strict-Transport-Security" 的回應標頭來與其用戶端通訊。此標頭的值是用戶端應該僅在 HTTPS 存取伺服器的時間。其他標頭屬性包含 "includeSubDomains" 和 "preload"。

### 受影響的產品：

此問題可能會影響各種類型的產品。

修正建議：

一般

藉由將 "Strict-Transport-Security" 回應標頭新增至 Web 應用程式回應，來實作 HTTP Strict Transport Security 原則。  
如需相關資訊，請參閱

[https://cheatsheetseries.owasp.org/cheatsheets/HTTP\\_Strict\\_Transport\\_Security\\_Cheat\\_Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html)

CWE：

200

693

外部參照：

OWASP "HTTP Strict Transport Security"

HSTS 規格

## 遺漏「查閱者原則」安全標頭

目錄

原因：

不安全的 Web 應用程式程式設計或設定

風險：

有可能收集有關 Web 應用程式的機密資訊，例如使用者名稱、密碼、機器名稱和/或機密檔案位置

有可能說服天真的使用者提供機密資訊，例如使用者名稱、密碼、信用卡號碼、社會安全碼等等

查閱者原則的值缺少或不適當可能會導致 URL 洩漏，即使是 URL 中所含的機密資訊，都會向跨網站洩漏。

這是一部分的規則集，可檢查是否設有查閱者原則，若有的話可以測試其設定。「查閱者原則」標頭會在查閱者標頭中定義可提供的資料，並且在目的地的 (document.referrer) 定義導覽和 iframe。此標頭的設計是為了要修改瀏覽器呈現頁面的方式，藉此避免跨網域的查閱者洩漏。正確設定標頭值很重要，設定方式不要妨礙網站的正常運作。

查閱者標頭是一個要求標頭，可表示流量來自哪個網站。如果沒有設有適當的防護，URL 本身，甚至是包含在 URL 中的機密資訊，都會向跨網站洩漏。

「no-referrer-when-downgrade」和「unsafe-url」是會洩露第三方網站完整 URL 的原則。剩餘的原則為「no-referrer」、「origin」、「origin-when-cross-origin」、「same-origin」、「strict-origin」、「strict-origin-when-cross-origin」。

詳情請參閱下方連結。

受影響的產品：

此問題可能會影響不同類型的產品

修正建議：

一般

設定伺服器以傳送「查閱者原則」標頭。

建議透過查閱者原則標頭的目錄安全值，設定查閱者原則標頭。如下所示：

"strict-origin-when-cross-origin" 提供更高的隱私權。有了此原則，只有來源會在跨來源要求的查閱者標頭中傳送。

如果是 Google Chrome，請參閱：

<https://developers.google.com/web/updates/2020/07/referrer-policy-new-chrome-default>

如果是 Firefox，請參閱：

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy>.

CWE：

200

664

668

外部參照：

MDN web 文件 - 查閱者原則



# 應用程式資料

## 造訪的 URL 4

目錄

| URL                                                        |
|------------------------------------------------------------|
| https://meqa.ncu.edu.tw/nurvo/                             |
| https://meqa.ncu.edu.tw/nurvo/assets/index-BtQqzhMN.js     |
| https://meqa.ncu.edu.tw/nurvo/assets/LoginView-BhefISG_.js |
| https://meqa.ncu.edu.tw/nurvo/api/auth/google              |

## 參數 0

目錄

| 名稱 | 值 | URL | 類型 |
|----|---|-----|----|
|----|---|-----|----|

## 失敗要求 0

目錄

| URL | 原因 |
|-----|----|
|-----|----|

## 已過濾的 URL 6

目錄

| URL                                                                                  | 原因           |
|--------------------------------------------------------------------------------------|--------------|
| https://meqa.ncu.edu.tw/nurvo                                                        | 可能類似的 DOM    |
| https://meqa.ncu.edu.tw/nurvo/favicon.ico                                            | 副檔名          |
| https://fonts.googleapis.com/                                                        | 未測試的 Web 伺服器 |
| https://fonts.gstatic.com/                                                           | 未測試的 Web 伺服器 |
| https://fonts.googleapis.com/css2?family=Inter:wght@400;500;600;700;800&display=swap | 未測試的 Web 伺服器 |
| https://meqa.ncu.edu.tw/nurvo/assets/index-CFQXcnSs.css                              | 副檔名          |

## 註解 1

目錄

| URL                            | 註解              |
|--------------------------------|-----------------|
| https://meqa.ncu.edu.tw/nurvo/ | <!DOCTYPE html> |

## URL / 程式碼

[https://meqa.ncu.edu.tw/nurvo/assets/LoginView-BheflSG\\_.js](https://meqa.ncu.edu.tw/nurvo/assets/LoginView-BheflSG_.js)

```
import {d as l,c as e,a,b as d,r as s,o as n,_ as c}from"./index-BtQqzhMN.js";const i={class:"login-container"},p=l({__name:"LoginView",setup(r){function o(){s()}return(f,t)=>(n(),e("div",i,[a("div",{class:"login-card"},[t[1]]|(t[1]=a("h1",null,"Nurvo",-1)),t[2]]|(t[2]=a("p",{class:"subtitle"},"護理溝通情境訓練系統",-1)),a("button",{class:"google-btn",onClick:o},[...t[0]]|(t[0]=[d('<svg xmlns="http://www.w3.org/2000/svg" viewBox="0 0 48 48" width="20" height="20" data-v-db2c400f><path fill="#EA4335" d="M24 9.5c3.54 0 6.71 1.22 9.21 3.616.85-6.85C35.9 2.38 30.47 0 24 0 14.62 0 6.51 5.38 2.56 13.2217.98 6.19C12.43 13.72 17.74 9.5 24 9.5z" data-v-db2c400f></path><path fill="#4285F4" d="M46.98 24.55c0-1.57-.15-3.09-.38-4.55H24v9.02h12.94c-.58 2.96-2.26 5.48-4.78 7.1817.73 6c4.51-4.18 7.09-10.36 7.09-17.65z" data-v-db2c400f></path><path fill="#FBBC05" d="M10.53 28.59c-.48-1.45-.76-2.99-.76-4.59s.27-3.14-.76-4.591-7.98-6.19C.92 16.46 0 20.12 0 24c0 3.88.92 7.54 2.56 10.7817.97-6.19z" data-v-db2c400f></path><path fill="#34A853" d="M24 48c6.48 0 11.93-2.13 15.89-5.811-7.73-6c-2.18 1.48-4.97 2.36-8.16 2.36-6.26 0-11.57-4.22-13.47-9.911-7.98 6.19C6.51 42.62 14.62 48 24 48z" data-v-db2c400f></path><path fill="none" d="M0 0h48v48H0z" data-v-db2c400f></path></svg> 使用 Google 帳號登入 ',2)]]]]]]]]]}},v=c(p,[["__scopeId","data-v-db2c400f"]]);export{v as default};
```

<https://meqa.ncu.edu.tw/nurvo/assets/index-BtQqzhMN.js>

```
const __vite_mapDeps=(i,m=__vite_mapDeps,d=(m.f||m.f=["assets/LoginView-BheflSG_.js","assets/LoginView-CHuH3rYT.css","assets/AuthCallbackView-BN722GbD.js","assets/AuthCallbackView-BFXqsPV.css","assets/BriefingView-B84gzGcx.js","assets/scenarioStore-m8EdFyq2.js","assets/audioService-DLI2Xu9G.js","assets/audioService-BPg372lx.css","assets/BriefingView-Ca5YoCNH.css","assets/LevelSelectView-DcblkUgR.js","assets/LevelSelectView-314PfvZx.css","assets/SceneView-BsLfYa50.js","assets/chatStore-Dzt09VeS.js","assets/SceneView-CKaoSXPy.css","assets/RecordView-BjTjp7Wo.js","assets/RecordView-D2KKnnIY.css","assets/DashboardView-BY0Op6Yf.js","assets/DialogueTimeline-DA6k7uVM.js","assets/DialogueTimeline-CEzHBoCx.css","assets/DashboardView-BUS5zo46.css","assets/HistoryView-B7c-oAg6.js","assets/HistoryView-Fm4AnrAB.css","assets/HistoryDetailView-D2K29BJQ.js","assets/HistoryDetailView-BIwW3tgX.css"]])>i.map(i=>d[i]);(function(){const o=document.createElement("link").relList;if(o&&o.supports&&o.supports("modulepreload"))return;for(const n of document.querySelectorAll('link[rel="modulepreload"]'))t(n);new MutationObserver(n=>{for(const i of n)if(i.type==="childList")for(const a of i.addedNodes)a.tagName==="LINK"&&a.rel==="modulepreload"&&t(a)}.observe(document,{childList:!0,subtree:!0});function r(n){const i={};return n.integrity&&i.integrity=n.integrity,n.referrerPolicy&&(i.referrerPolicy=n.referrerPolicy),n.crossOrigin==="use-credentials"?i.credentials="include":n.crossOrigin==="anonymous"?i.credentials="omit":i.credentials="same-origin",i}function t(n){if(n.ep)return;n.ep=!0;const i=r(n);fetch(n.href,i)}function An(e){const o=Object.create(null);for(const r of e.split(","))o[r]=1;return r=>r in o}const se={},sr=[],mo=()=>({}),Pa=()=>=>{!1,$t=e=>e.charCodeAtAt(0)===111&&e.charCodeAtAt(1)===110&&(e.charCodeAtAt(2)>122||e.charCodeAtAt(2)<97),_t=e=>e.startsWith("onUpdate:"),ke=Object.assign,On=(e,o)=>{const r=e.indexOf(o);r>-1&&e.splice(r,1)},Ol=Object.prototype.hasOwnProperty,te=(e,o)=>Ol.call(e,o),H=Array.isArray,lr=e=>Kr(e)===[object Map],Na=e=>Kr(e)===[object Set],ii=e=>Kr(e)===[object Date],Ye=e=>typeof e==="function",fe=e=>typeof e==="string",Ve=e=>typeof e==="symbol",ne=e=>e!==null&&typeof e==="object",Ia=e=>(ne(e)||Y(e))&&Y(e.then)&&Y(e.catch),Da=Object.prototype.toString,Kr=e=>Da.call(e),Tl=e=>Kr(e).slice(8,-1),La=e=>Kr(e)===[object Object],St=e=>fe(e)&&e!=="NaN"&&e[0]!=="-","&&"+parseInt(e,10)===e,$r=An(""),key,ref,ref_for,ref_key,onVnodeBeforeMount,onVnodeMounted,onVnodeBeforeUpdate,onVnodeUpdated,onVnodeBeforeUnmount,onVnodeUnmount,Bt=e=>{const o=Object.create(null);return(r=>o[r]||(o[r]=e(r))),Pl=/-\/w/g,Le=Bt(e=>e.replace(Pl,o=>o.slice(1).toUpperCase())),Nl=/\B([A-Z])/g,zo=Bt(e=>e.replace(Nl,"-$1").toLowerCase()),Rt=Bt(e=>e.charAt(0).toUpperCase()+e.slice(1)),Vt=Bt(e=>e?'on${Rt(e)}':""),go=(e,o)=>Object.is(e,o),it=(e,...o)=>{for(let r=0;r<e.length;r++)e[r](...o)},Ma=(e,o,r,t=!1)=>{Object.defineProperty(e,o,{configurable:!0,enumerable:!1,writable:t,value:r}),Tn=e=>{const o=parseFloat(e);return isNaN(o)?e:o},Il=e=>{const o=fe(e)?Number(e):NaN;return isNaN(o)?e:o};let ai;const Et=()=>ai||(ai=typeof globalThis<"u"?globalThis:typeof self<"u"?self:typeof window<"u"?window:typeof global<"u"?global:{});function Pn(e){if(H(e)){const o={};for(let r=0;r<e.length;r++){const t=e[r],n=fe(t)?j1(t):Pn(t);if(n)for(const i in n)o[i]=n[i]}return o}else if(fe(e)||ne(e))return e;const Dl=/;(?![^()*\])\/g,Ll=/:([^\s]+)/g,Ml=/\/\*[\s\S]*?\*\/g;function j1(e){const o={};return e.replace(Ml,"").split(Dl).forEach(r=>{if(r){const t=r.split(Ll);t.length>1&&(o[t[0].trim()]=t[1].trim())}},o);function At(e){let o="";if(fe(e))o=e;else if(H(e))for(let r=0;r<e.length;r++){const t=At(e[r]);t&&(o+=t+"")}else if(ne(e))for(const r in e)e[r]&&(o+=r+"");return o.trim()}const Fl="itemscope,allowfullscreen,formnovalidate,ismap,nomodule,readonly",zl=An(Fl);function ja(e){return!!e||e===""}function Wl(e,o){if(e.length!==o.length)return!1;let r=!0;for(let t=0;t<e.length;t++)r=Nn(e[t],o[t]);return r}function Nn(e,o){if(e===o)return!0;let r=ii(e),t=ii(o);if(r||t)return r&&t?e.getTime()===o.getTime():!1;if(r=Ve(e),t=Ve(o),r||t)return e===o;if(r=H(e),t=H(o),r||t)return r&&t?Wl(e,o):!1;if(r=ne(e),t=ne(o),r||t){if(!r||!t)return!1;const n=Object.keys(e).length,i=Object.keys(o).length;if(n!==i)return!1;for(const a in e){const s=e.hasOwnProperty(a),l=o.hasOwnProperty(a);if(s&&!l||!s&&l||!Nn(e[a],o[a]))return!1}}return String(e)===String(o)}const Fa=e=>!!(e&&e.__v_isRef===!0),ut=e=>fe(e)?e:e===null?"":H(e)||ne(e)&&(e.toString()===Da||!Y(e.toString()))?Fa(e)?ut(e.value):JSON.stringify(e,za,2):String(e),za=(e,o)=>Fa(o)?
```

```

za(e,o.value):lr(o)?[Map($o.size)]:[...o.entries()].reduce((r,[t,n],i)=>(r[Ut(t,i)+" =>"]=n,r),{}):Na(o)?
[Set($o.size)]:[...o.values()].map(r=>Ut(r)):Ve(o)?Ut(o):ne(o)&&!H(o)&&!La(o)?String(o):o,Ut=(e,o="")=>{var
r;return Ve(e)?Symbol(${(r=e.description)!=null?r:o}):e};let Re;class Wa{constructor(o=!1)
{this.detached=o,this._acti...

```

## Cookie 0

目錄

| 名稱 | 第一個集合    | 網域 | 安全 | 僅限 HTTP | 相同網站 | JS 堆疊追蹤 |
|----|----------|----|----|---------|------|---------|
| 值  | 所要求的 URL |    | 到期 |         |      |         |

## 元件 1

目錄

| 名稱  | 版本   | URL                                           |
|-----|------|-----------------------------------------------|
| IIS | 10.0 | https://meqa.ncu.edu.tw/nurvo/api/auth/google |